Review coverage, workflow traces and analytical responsibilities

This is one agent's multidisciplinary review, not independent approval by 22 people. File-level depth is recorded in coverage.json. All first-party code/config files found by the stated inventory rules were enumerated and fingerprinted. Source review concentrates on the shared trust boundaries, every API handler and representative critical domain paths. Large service files were reviewed in relevant ranges; the remaining lines are not represented as manually audited.

Trust model

Protected assets are tenant business data, employee/private evidence, inventory and ledger truth, credentials, signed/approval evidence and operational authority. Actors include anonymous link holders, users of the current/foreign tenant, administrators, external accountants, provider identities, workers, approvers and read-only agents.

The important boundaries are browser-to-action, API-to-service, signed token-to-live registry, organization-to-object query, business mutation-to-transaction/outbox, worker-to-provider, human decision-to-effective approval and raw data-to-redacted UI/export. Cookie presence in middleware is an optimistic routing hint. Authority resides in the server session, permission and organization checks. Hashes bind content and do not identify a signer.

Traced workflows

Workflow	Source path traced	Controls/behavior observed	Remaining verification
Sign-in and ordinary authorization	lib/auth.ts → lib/security/rbac.ts → server-authz.ts / services/_shared/protect.ts	Current user/org/permissions loaded; revoked cached session gap corrected; tenant mismatch denied	Real HTTPS sign-in/revocation, provider reset and infrastructure behavior
Dashboard navigation	middleware.ts → i18n/routing.ts → protected pages/actions	Both secure and local session cookies recognized; original callback retained	Browser route smoke on deployment
Tenant item/organization APIs	app/api/v1/organisations routes → server-authz → item/organization read services	Session/org, permission, enforced module and bounded item pagination	Full resource matrix on real multi-tenant DB
Photo upload to display	photo-upload-actions → storage-config-actions → public directory → EnhancedImageUploadButton; alternate uploads API	Write permission/org checks; API tenant check/path/MIME allowlist; public static bypass and non-durable configuration found	Private migration, byte validation and legacy/optimizer access matrix
Receipt access	receipts route → receipt.service → public-receipt-token-registry	Signed expiring token and live access record; public contact redaction	Deployed cache/referrer/retention verification
Customer statement link/actions	customer-statements routes → customer-statement-access	Token hash, live status/revocation/expiry, snapshot content binding, action scope, access audit and redaction	Real replay/revocation race; complete import/export body-abuse assessment

Workflow	Source path traced	Controls/behavior observed	Remaining verification
Supplier acknowledgment	supplier-po-envelopes routes → supplier-po-acknowledgement	Token/envelope integrity, transaction audit, external proposals rather than direct authoritative purchase-order changes	Persisted multi-transaction replay and callback tests
POS/offline replay	actions/pos/sync.actions → offline-sync → pos.service / accounting/event interfaces	Server-derived user/org; batch schema, idempotency and sequence conflicts, device signature/policy states; provisional close blockers retained	Real PostgreSQL simultaneous replay, connectivity-loss/browser proof
AP invoice/payment release	ap-control.actions → ap-control.service → transaction/posting/events	Server identity; approval controls; approved destination binding; distinct requester, approver and releaser; idempotency replay	Actual database and provider ambiguity/partial-failure evidence
Payroll approval/posting	payroll-control.actions → payroll-control.service → transition/event/posting history	Enforced payroll module, immutable review evidence, actor separation, version compare-and-set, serializable transaction and bounded conflict retry	Candidate-bound PostgreSQL triggers, concurrent commands and rollback proof
Employee self-service	hris self-service → own employee/payment/time services; payslip controls	Permission checks, own-profile composition, masked destination and explicit unavailable raw documents	Browser employee/manager scope, accessibility and real data isolation
Ledger posting/reversal/close invalidation	posting.service → invariants / source-link / journal-close-invalidation	Decimal money, currency balance, same-org accounts, open periods, source-owned reversal restriction; reversal numbering race candidate	Two-transaction reproduction and evidence that all sources retain atomicity
Finance export	protected export actions → finance-statement-export → sensitive action → event/outbox → leased artifact completion	Tenant/client-request binding, payload conflict, worker ownership; JSON MIME and audit metadata corrected	Configured renderer, private download grant, embedded watermark and retention
Provider/outbox work	business-event-outbox → compare-and-set lease/delivery/failure	Organization/channel scope, bounded claim count, max attempts, dead-letter state, worker-owned acknowledgement	Actual provider retries/timeouts and out-of-order delivery
Reconciler endpoint	internal route → reconciler-auth / invocation → control-plane reconciliation	Secret verification, run ID, time window, replay/in-progress checks and stored outcome	Real schedule, alert transport and three operating windows
Agent request/tool execution	runner → tool registry → agent policy → command adapters → evidence/history	Registered known read-only tools; permission and evaluated entitlement; prohibited writes; trusted evidence/redaction	Deadline propagation, cancellation, live identity/cost/abuse exercises
Analytics	financial-analytics → organization/location queries and payroll redaction/entitlement → metrics	Parallel independent reads and explicit data boundaries; historical COGS uses mutable item cost	Posted cost source, metric tie-out, query plans and large-volume measurements
X1 evidence	observer → capture specs/aggregation → preflight/binding validator	Explicit ready/empty/error/summary semantics; current missing approvals and artifacts reported accurately	Fresh authenticated 42-case matrix, budget proof and candidate binding

Workflow	Source path traced	Controls/behavior observed	Remaining verification
Human approval record	blueprint → proposed models/routes; current provider contract	Native register absent; simulator does not convey authority; first-time establishment design avoids prior-ID recursion	Implement P07 and obtain actual establishment/decision evidence
CI and delivery	package scripts → CI workflow → migration/build/policy graph	CI uses isolated PostgreSQL, least-privilege repository token and explicit stages; npm and installed graphs differ	Patched frozen build, deployed target/backup/secret/restore proof

These traces establish source relationships and selected control behavior. They do not certify every branch, query, UI state, provider or migration. Mock-based tests cannot establish database locking, trigger enforcement or deployed security.

All requested review responsibilities

Responsibility	Evidence-supported assessment
Enterprise/platform architecture	Shared protect/RBAC/event ownership is worth preserving. Large payroll/AP services need incremental extraction along existing transaction boundaries, not a wholesale rewrite. Graph hints were verified against current source.
Backend/domain/integration	AP and payroll derive identity server-side; outbox lease/idempotency mechanisms are explicit. Real concurrent/provider proof remains necessary (F13/F14).
Data/database/migrations	Decimal fields and tenant/entry uniqueness are present; schema validates. No migration or database mutation was run. X02 and target-specific restore/history evidence remain.
Security/IAM/privacy/abuse	F01–F04, F06–F09 and F16 identify concrete fixes and unresolved exposure. No claim of unhackability or complete penetration testing.
Frontend/design system	Shared table contracts and robust-state attributes provide a useful common surface. Finance contract and secure-cookie routing defects were corrected.
Workflow UX/accessibility/localization	X1 recognizes loading/error/empty/summary distinctly. EN/FR and three viewports are enumerated; screen-reader and authenticated visual proof remain unperformed. Storage labels/limits must reflect real configuration (F15).
Product/business process	Keep the documented narrow pilot as provisional scope. P01–P08 order technical corrections before candidate activation; user action U01 resolves milestone scope.
Quality/release assurance	Baseline failures are retained; focused negative tests pass after corrections. Inventory now exposes unknown guards instead of implying complete coverage.
SRE/performance/cost	F08/F09/F14 require transport, distributed limits and cancellation. Old X1 timings are invalid for route performance; new measurements are required before optimization.
SaaS packaging/billing/growth/customer success	Module entitlement decisions and agent enforcement were inspected; local/CI and observe/enforce distinctions remain visible. Do not claim paid-package isolation across every unreviewed surface. Billing/provider commercialization needs the X01 registry and actual provider acceptance evidence.
Finance/OHADA/treasury/internal controls	Balanced Decimal journals and AP actor separation should remain. Historical analytics cost is unreliable until tied to posted evidence (F10). No professional accounting certification.

Responsibility	Evidence-supported assessment
Statutory/tax/payroll/labor/privacy/country packs	Effective-dated pack resolution, capability boundaries and source provenance are present. Qualified expert/checker evidence and actual legal applicability remain B05/B06/U07.
Audit/evidence/records/data quality	Revision/hash/expiry semantics matter; generated reports and native authority are different. P07 preserves append-only decisions and verified source links.
POS/inventory/offline/distributed consistency	Offline schema, signed-device policy, sequence/idempotency conflict and close-blocker concepts remain. Real replay and disconnection proof are outstanding.
Purchasing/supplier/AP	Release binds to approved supplier destination and three distinct actor roles. Preserve three-way match exceptions and transaction idempotency.
HRIS/compensation/attendance/self-service	Own-profile and masked payment data composition is explicit; payroll transition/version/approval tests passed. Complete UI and real access proof remain.
Payments/mobile money/settlement/providers	Reconciliation-run tests and outbox leases were checked. No actual money was moved; provider settlement ambiguity and operating evidence remain external.
Close/fiscal/reporting/accountant	Source-owned journal reversal and close invalidation are explicit; export/measurement corrections improve evidence integrity. Close readiness and statutory approvals remain distinct.
Analytics/BI/metric governance	F10 is a concrete historical-cost weakness; arrays over full date ranges warrant measured query/aggregation work, not speculative caching.
AI/agent safety/evaluation/approval	Read-only tool registry and actor/module policy are explicit; timeout is not cancellation. Native human approvals cannot be created by the agent or simulator.
APIs/webhooks/events/import/export	All 17 handlers were inspected; delegated-service coverage is separately recorded. F03/F04/F06 and P03 address parser/framework/inventory exposure; deployed provider authenticity remains untested.
Change management/docs/training/support	USER_ACTIONS explains who supplies missing information and where it comes from. Existing gate evidence is scoped to its actual candidate/environment and retained as history.

Graph context and exclusions

graphify-out graph snapshots contain 1,044 action nodes, 622 app nodes, 1,173 component nodes, 308 hook nodes and 72 type nodes. Examples used as navigation hints include action community 0 (auth), community 6 (close-assurance actions), community 9 (agent release actions), and hook communities 21/30 referenced by the prior finance investigation. These graphs may predate current source; node counts are not review coverage.

Generated/vendor/build outputs, dependencies, copied historical workspaces and private runtime artifacts are excluded from first-party source review. Third-party versions and selected advisories are assessed separately. The broad pattern scan's eight raw-SQL candidates were inspected: fixed statements or parameterized values did not establish SQL injection. One diagnostic's credential logging was separately corrected (F16). This scan is not a comprehensive secret or vulnerability scanner.